

ИНТЕЛЛЕКТУАЛЬНАЯ СИСТЕМА АНАЛИЗА КИБЕРУГРОЗ НА ОСНОВЕ НЕЙРОСЕТЕВОЙ ПЛАТФОРМЫ RAG-GRAPH: ПРОГРАММНО-ТЕХНИЧЕСКОЕ ОБЕСПЕЧЕНИЕ

В.Ю. Остапенко, Д.О. Карпеев, А.Л. Сердечный, А.П. Васильченко

Современные системы анализа киберугроз сталкиваются с фундаментальным вызовом: необходимо быстро синтезировать информацию из множества разнородных источников данных, сохраняя при этом контекст и точность. Большие языковые модели (LLM), несмотря на свои возможности, часто страдают от галлюцинаций и недостаточной глубины понимания сложных связей между сущностями киберпреступлений. Традиционные подходы на основе текстового поиска (full-text search) неэффективны для выявления скрытых паттернов взаимодействия между группировками, техниками атак и уязвимостями. В данной статье представлена архитектура RAG-Graph, которая объединяет три компонента в единую систему: графовые базы знаний для структурирования связей между сущностями, векторные базы данных для семантического поиска, и локальные LLM для интеллектуальной генерации аналитических отчётов. Ключевая инновация заключается в комбинировании графового обхода с векторным сходством, что позволяет решать критически важные задачи кибербезопасности.

Ключевые слова: RAG-Graph, векторизация, искусственный интеллект, киберпреступность, граф знаний.

Введение

Стремительное развитие цифровых технологий приводит к росту масштабов и сложности кибератак, что существенно повышает требования к системам обеспечения информационной безопасности. Согласно статистике ведущих аналитических центров, количество целевых атак на организации ежегодно увеличивается, при этом наблюдается рост доли сложных многоступенчатых атак, использующих автоматизацию, социальную инженерию и гибридные методы воздействия [1, 2]. Одновременно растёт активность киберпреступных группировок, которые активно адаптируют свои инструменты под особенности инфраструктуры жертв и быстро внедряют новые эксплойты и тактики [3].

В условиях столь динамичного киберландшафта традиционные средства обеспечения безопасности — основанные на сигнатурных методах, статических моделях угроз и ручном анализе инцидентов — демонстрируют всё меньшую эффективность [4]. Основные проблемы заключаются в отсутствии целостных моделей знаний о домене киберугроз, сложности обработки

больших объёмов неструктурированных данных и недостаточной способности реагировать на ранее неизвестные сценарии атак.

Одним из наиболее перспективных подходов к решению обозначенных задач является использование графовых моделей знаний, которые позволяют формализовать сущности предметной области (уязвимости, группировки, техники атак, инциденты) и связи между ними [5, 6]. Графовые представления обеспечивают возможность аналитических запросов высокой сложности, включая моделирование сценариев атак, выявление скрытых взаимосвязей и проведение причинно-следственного анализа [5].

Параллельно широкое распространение получает архитектура RAG (Retrieval-Augmented Generation) — гибридный подход, объединяющий поиск релевантной информации и возможности больших языковых моделей [7]. Однако существующие RAG-системы ориентированы преимущественно на векторный поиск и не обеспечивают полноценного анализа структурированных

знаний, что ограничивает их применимость в задачах информационной безопасности, требующих строгой интерпретируемости и формальных связей между объектами [8].

Для преодоления данных ограничений в работе предлагается нейросетевая платформа RAG-Graph, объединяющая граф знаний, векторную базу данных и генеративную нейросеть в единую архитектуру. Такой подход позволяет одновременно использовать:

- 1) графовые представления для структурного анализа угроз;
- 2) векторные представления текста для эффективного поиска;
- 3) LLM для генерации аналитических выводов, основанных на фактах, извлечённых из графа и текстовых источников.

Цель исследования заключается в разработке и реализации программно-технического обеспечения интеллектуальной системы анализа киберугроз на основе гибридной архитектуры RAG-Graph.

Для достижения цели решаются следующие **задачи**:

- 1) провести обзор ключевых технологий, применяемых при построении RAG-Graph систем анализа киберугроз, включая графовые БД, векторные хранилища, LLM, методы NER/RE и конвейеры извлечения знаний;
- 2) разработать онтологическую модель предметной области киберугроз, включающую сущности и их атрибуты, а также формальные типы связей между ними;
- 3) реализовать нейросетевой конвейер извлечения сущностей и связей (NER/RE), обеспечив дедубликацию и нормализацию данных;
- 4) построить граф знаний в Neo4j и определить механизмы его интеграции с векторной БД;
- 5) разработать архитектуру RAG-Graph и определить взаимодействие между компонентами в процессе анализа угроз и рисков;
- 6) продемонстрировать прикладные задачи, решаемые системой, такие как извлечение исходных данных для оценки риска эксплуатации уязвимостей и автоматизация формирования компенсирующих мер.

Научная новизна работы заключается в разработке гибридной архитектуры анализа киберугроз, объединяющей графовые модели, векторный поиск и генеративные нейросети в единую систему, обеспечивающую интерпретируемость, гибкость и расширяемость анализа. Практическая значимость заключается в возможностях использования разработанной платформы для повышения качества оценки рисков, снижения времени реакции на угрозы и автоматизации процессов поддержки принятия решений.

1. Обзор ключевых технологий, используемых в RAG-Graph Cyber Risk

Система опирается на сочетание нескольких взаимодополняющих технологий, обеспечивающих извлечение, структурирование и анализ данных из разнородных источников. В основе лежат современные нейросетевые модели, способные выполнять семантический поиск, извлечение сущностей и формирование контекстных представлений текста [9, 10]. Эти модели позволяют преобразовывать неструктурированные данные — новости, отчёты, материалы из открытых источников — в удобный для анализа формат.

Дополняющим компонентом выступают векторные представления данных (эмбединги), которые фиксируют семантическое содержание текста в виде числовых векторов [11]. Хранение таких векторов осуществляется в специализированных векторных базах данных, оптимизированных для быстрого поиска ближайших соседей и кластеризации смыслово связанных объектов. Это обеспечивает эффективное извлечение релевантных фрагментов информации даже в больших массивах текстов.

Для структурирования связей между извлечёнными сущностями используется графовое моделирование. Графовые базы данных позволяют формировать сети отношений, в которых узлы представляют ключевые сущности (группировки, методы атак, события, инфраструктура), а рёбра — связи между ними [12]. Такой подход удобен для анализа сложных взаимосвязей,

характерных для области информационной безопасности.

В качестве объединяющего элемента используется архитектура Retrieval-Augmented Generation (RAG). Её ключевая особенность — интеграция внешних знаний в процесс генерации, что преодолевает ограниченность внутренних параметров LLM-модели. RAG осуществляет целенаправленный поиск информации в векторной базе данных и обеспечивает подачу строго релевантного контекста, благодаря чему модель формирует обоснованные и верифицируемые выводы [7, 13]. Расширением этой идеи является подход GraphRAG, позволяющий использовать не только векторный поиск, но и навигацию по графу знаний [14, 15]. Это обеспечивает двухуровневое извлечение информации: сначала по смысловой близости, затем — по структурным связям. Таким образом, система сочетает семантический поиск и анализ графовых отношений, что особенно важно в задачах, связанных со сложными киберугрозами, множеством участников и цепочками событий.

2. Модель знаний о киберугрозах

Для анализа угроз и построения риск-ориентированных заключений требуется структурированное представление данных, объединяющее разнородные сведения: уязвимости, инструменты атак, злоумышленников, события и последствия. Такая модель знаний позволяет систематизировать факты, извлечённые из открытых источников, выделить ключевые сущности и отношения между ними, а затем использовать их для построения графа знаний. Все дальнейшие алгоритмы обработки — от извлечения сущностей до построения графовой структуры в Neo4j — основаны именно на этой модели.

2.1 Онтология предметной области

Для работы с данными о киберугрозах важно не просто извлечь текстовые фрагменты, а представить их в виде цельной и формальной модели знаний. Такая модель — онтология — определяет, какие сущности

действительно имеют аналитическую ценность, какие отношения между ними существенны, а какие стоит игнорировать, чтобы не перегружать систему лишней информацией [16].

В процессе разработки была сформирована прикладная онтология, ориентированная не на максимально возможное покрытие, а на прагматичную полезность для последующего анализа рисков и построения графа угроз. Это позволило сфокусироваться на сущностях, которые:

1) регулярно встречаются в киберразведывательных данных (новости, отчёты СТИ, посты в социальных сетях);

2) имеют прямое влияние на оценку рисков (акторы, техники атак, уязвимости, последствия);

3) хорошо формализуются через существующие системы классификаций (MITRE ATT&CK, CVE/CWE, типы инфраструктур) [17, 18];

4) образуют устойчивые паттерны связей, которые можно выявлять алгоритмами графового анализа.

Таким образом, онтология стала не универсальным описанием всех возможных объектов ИБ, а инструментом, оптимизированным под конкретную задачу: формирование графа знаний и автоматическое построение сценариев риска.

Структура онтологии опирается на строго определённую группу сущностей, представленных в табл. 1.

Для повышения качества формируемого графа знаний было принято решение ввести ограничения на типы допустимых связей между сущностями. Это позволяет структурировать семантические отношения, снизить уровень шума и повысить точность выводов, получаемых на основе графа. В табл. 2 представлены основные типы связей, которые были определены как релевантные для предметной области.

Помимо прочего сущности и связи, при хранении, содержат ещё и краткое описание, дающие им пояснение в соответствии с контекстом их обнаружения.

Таблица 1

Перечень рассматриваемых сущностей

Категория	Краткое описание	Пример значения
VULNERABILITY	Описывает конкретную уязвимость/слабость (CVE/текст)	CVE-2024-12345
CWE	Класс уязвимости (тип)	CWE-89 (SQL Injection)
THREAT_ACTOR	Группировка/злоумышленник	APT29
MALWARE	Вредоносное ПО	LockBit 3.0
EXPLOIT	Эксплойт/модуль	EternalBlue
ATTACK_TECHNIQUE	Техника/тактика (MITRE/CAPEC)	T1210 (Exfiltration)
TARGET_ASSET	Цель атаки (система/сервис)	Active Directory
PRODUCT	Продукт/ПО	Windows Server 2019
ORG	Организация	Acme Corp.
PER	Персоналия	John Doe
EVENT	Инцидент/кампания	Supply-chain breach 2024-05
RISK_SCENARIO	Сценарий риска/последствие	Data Breach
SECURITY_CONTROL	Контрмера/средство	EDR
CIA_IMPACT	Нарушение триады КИД	confidentiality
DATE	Дата	2024-05-12
GPE / NORP / LANGUAGE / MONEY / PRODUCT / LAW / EVENT / ...	Вспомогательные сущности для контекста	—

Таблица 2

Перечень рассматриваемых связей

Отношение	Источник / типы источников	Цель / типы целей	Краткое описание
exploits	THREAT_ACTOR / EXPLOIT / ATTACK_TECHNIQUE	VULNERABILITY / TARGET_ASSET	Эксплуатация уязвимости или атака на актив
uses	THREAT_ACTOR / ORG	EXPLOIT / MALWARE / ATTACK_TECHNIQUE	Использует инструмент/технику
delivers	EXPLOIT / THREAT_ACTOR	MALWARE / PAYLOAD	Доставка полезной нагрузки
installs_on	MALWARE	TARGET_ASSET	Инсталляция на актив
communicates_with	MALWARE / INFRASTRUCTURE	IP / DOMAIN / SERVER	Связь с C2
controls	THREAT_ACTOR	BOTNET / INFRASTRUCTURE	Управляет инфраструктурой
attributed_to	EVENT / CAMPAIGN	THREAT_ACTOR / ORG	Приписывается актору
leads_to	VULNERABILITY / ATTACK_TECHNIQUE	RISK_SCENARIO	Ведёт к сценарию риска
impacts_cia	VULNERABILITY / ATTACK_TECHNIQUE / EVENT	CIA_IMPACT	Связь с нарушением триады
mitigates / detects / prevents	SECURITY_CONTROL	VULNERABILITY / ATTACK_TECHNIQUE / MALWARE	Меры защиты
categorized_as / maps_to	VULNERABILITY / CWE	CWE / ATTACK_TECHNIQUE	Классификация и маппинг
reports	ORG	VULNERABILITY / EVENT	Публикация отчёта
associated_with / affiliated_with / member_of	любой/ORGANIC	любой	Слабая / формальная связь

2.2 Извлечение сущностей и связей

Процесс извлечения знаний из текстовых источников в рамках построения графа угроз включает два ключевых аспекта: выделение значимых сущностей и определение семантических связей между ними. Однако в отличие от классических задач NER/RE, где работа ведётся в узкой доменной области и с заранее размеченными корпусами, здесь данные поступают из открытых источников, разнообразных по структуре, стилю и языку. Это делает задачу существенно сложнее и требует адаптированного подхода.

В качестве основной технологии для извлечения было решено использовать LLM-модели общего назначения, а не специализированные NER-модели [9, 19]. Такое решение обусловлено тем, что существующие NER-системы:

1) не обладают необходимой мультиязычностью — большинство качественных моделей ориентированы на английский язык [20];

2) слабо охватывают домен информационной безопасности — нет готовых теггеров, способных корректно распознавать технику MITRE ATT&CK, типы инфраструктуры, киберугруппировки, вредоносное ПО, CVE-идентификаторы и т. п.;

3) плохо обрабатывают слабоструктурированные тексты, характерные для новостных сводок и OSINT-источников (фрагментарные сообщения, телеграм-каналы, технические блоги).

LLM, напротив, демонстрируют способность работать с широким контекстом, понимать семантические связи и корректно интерпретировать объекты, специфичные для кибербезопасности, даже при отсутствии строгих разметки.

Первым шагом модель получает текст и определяет, какие его элементы соответствуют категориям из онтологии. Ограниченный словарь категорий был выбран специально, чтобы избежать «рассыпания» графа на множество нерелевантных объектов.

На этом этапе LLM фактически выполняет функцию семантического фильтра:

1) отличает, например, вредоносное ПО от обычного названия программы;

2) выделяет реальную киберугруппировку, а не просто упомянутое имя компании;

3) интерпретирует даты, техники, последствия и уязвимости в контекстно корректном виде.

Одновременно с типизацией извлекается краткое описание сущности, что обеспечивает дальнейшую интерпретируемость узлов графа и позволяет избежать неоднозначностей при дедубликации.

Второй этап направлен на установление связей между найденными сущностями. Вместо свободной интерпретации используется фиксированный набор типов отношений, сформированный по принципу: только те связи, которые несут аналитическую ценность и отражают причинно-следственные цепочки угроз.

LLM сопоставляет контекст текста и определяет, какие сущности находятся в отношении:

1) эксплуатация уязвимости;

2) использование инструмента;

3) доставка малвари;

4) принадлежность «человек → группировка»;

5) отображение «CVE → CWE»;

6) причинно-следственная связь между техникой и последствиями и т. д.

Поскольку модель опирается на общий смысл текста, она способна выявлять связи даже там, где они выражены неявно, например:

• «атака, позволяющая злоумышленникам получить доступ...» → связь `leads_to`;

• «использовав эксплойт EternalBlue...» → связь `uses`;

• «уязвимость привела к утечке данных» → `impacts_cia + leads_to`.

Такой подход делает граф более насыщенным и ближе к реальным аналитическим практикам СТИ.

После извлечения сущностей и связей необходимо устранить дубли, вариации написания и неоднозначности. Это особенно актуально для:

• техник MITRE (конвертация разных названий в единый идентификатор Txxxx),

• названий группировок (APT29 = Cozy Bear),

• ПО и инфраструктуры (Windows Server 2016 = Windows Server).

LLM используется и на этом этапе: модель определяет, соответствуют ли два упоминания одной сущности, сопоставляя их контекстные описания.

Дедупликация обеспечивает:

- 1) компактность графа,
- 2) устойчивость к «шумным» данным,
- 3) корректную работу алгоритмов кластеризации (в т.ч. Лейдена).

На финальном этапе результаты извлечения упаковываются в строго определённый формат:

- список сущностей;
- список связей (каждая связь содержит тип, источник, цель);
- краткие описания;
- атрибуты, необходимые для построения графа.

Структурированность данных позволяет:

- загружать их в Neo4j без дополнительной ручной обработки,
- применять алгоритмы анализа графов,
- автоматически строить цепочки атак,
- группировать сущности алгоритмом Лейдена.

2.3 Формирование графа знаний и алгоритм Лейдена

После того как сущности и связи успешно извлечены из текстов, начинается один из самых концептуально важных этапов — построение графа знаний. Именно граф становится структурой, которая «склеивает» разрозненные фрагменты информации в единую логическую картину. Он позволяет не просто хранить данные, но и анализировать их взаимосвязи, выявлять скрытые зависимости, определять ключевые узлы и обнаруживать сообщества внутри предметной области. В контексте анализа киберугроз и хакерских группировок такая структура особенно актуальна: граф показывает, как группировки, методы, инфраструктуры и события переплетены между собой, образуя сетевую модель угроз.

Граф знаний в системе построен на классическом представлении:

- Узлы (nodes) — это сущности предметной области: группы, тактики атак, уязвимости, инструменты, жертвы, инфраструктуры, события, индикаторы компрометации и др.

- Рёбра (edges) — типизированные связи между сущностями: «использует», «атакует», «связан с», «эксплуатирует», «взаимодействовал через», «принадлежит инфраструктуре» и прочие семантически осмысленные отношения.

Таким образом система получает предсказуемый и интерпретируемый граф, в котором можно выполнять аналитические запросы.

Граф формируется постепенно, по мере обработки данных:

1. Нормализация сущностей

Даже если одно и то же имя группы указано разными способами (например, “APT28”, “Fancy Bear”, “Sofacy”), система сопоставляет их с единой сущностью. Это предотвращает появление дубликатов и разрывов в структуре графа.

2. Агрегация фактов

Каждый новый обнаруженный факт (например: «группа X использует метод атак Y») добавляется в граф как новое ребро или усиливает существующее (в зависимости от числа источников). Так формируется взвешенный граф, где более подтверждённые связи имеют больший вес.

3. Контекстный анализ связей

Иногда связи возникают не напрямую, а через цепочку событий — например, инфраструктура может быть связана с группой только через конкретную кампанию. В таких случаях граф создаёт промежуточные узлы-события, позволяя хранить причинно-следственные связи, а не только статические ассоциации.

4. Обогащение графа внешними данными

При наличии интеграций граф может дополняться сведениями из открытых баз (например, списка CVE для уязвимостей), что делает его более информативным и полезным для аналитики.

Когда граф разрастается, становится трудно рассматривать его вручную — тысячи узлов и десятки тысяч связей образуют сложную сеть. Для выделения значимых фрагментов применяется кластеризация графа, целью которой является:

- обнаружение взаимосвязанных сообществ (например, акторов, использующих похожие тактики);

- выявление скрытых групп угроз;
- определение кластеров событий и кампаний;
- выделение областей интереса для дальнейшей автоматизированной или ручной аналитики.

Для решения этой задачи используется один из наиболее современных методов кластеризации больших графов — алгоритм Лейдена [21].

Алгоритм Лейдена (Leiden) — это развитие хорошо известного метода Louvain, но с устранением ключевых недостатков предшественника. Он применяется для разбиения графа на сообщества с максимальной внутренней плотностью связей.

Выбор алгоритма Лейдена обусловлен следующими аспектами.

1. Гарантированная связность сообществ

В алгоритме Louvain иногда возникали «разорванные» кластеры — сообщество могло состоять из нескольких несвязанных частей. Алгоритм Лейдена устраняет этот недостаток и гарантирует, что каждое выявленное сообщество является реально связным подграфом.

2. Более высокая точность и стабильность

Лейден применяет трёхфазный процесс оптимизации, позволяющий находить более качественные решения, чем Louvain, и избегать «локальных ям», где алгоритм застревает.

3. Эффективность на больших графах

Для предметной области кибербезопасности графы могут содержать тысячи или миллионы связей. Алгоритм Лейдена масштабируется и работает достаточно быстро даже на больших сетях.

После того как граф сформирован, происходит кластеризация, позволяющая обнаружить сообщества внутри него. В рамках анализа киберугроз это может проявляться так:

- выявление группировок, использующих одинаковые инструменты или инфраструктуру;
- автоматическое определение тактических паттернов поведения;
- объединение связанных событий атаки в логические кампании;

- обнаружение «центров влияния» — узлов, которые оказывают сильное влияние на структуру графа.

Процесс выглядит следующим образом:

1) подготовка взвешенного графа,

2) запуск алгоритма Лейдена. Алгоритм проходит по графу и формирует сообщества, оптимизируя модульность — показатель того, насколько хорошо граф разделён на плотные внутренние группы,

3) анализ полученных кластеров.

Кластеры интерпретируются аналитически, становятся основой для прогнозирования рисков, определения зон повышенной активности атакующих, построения отчётов и формирования контекстов для RAG-модели.

Таким образом, формирование графа знаний и применение алгоритма Лейдена создают структурную основу всей системы, позволяя превращать набор разрозненных текстов в логическую, аналитически полезную модель предметной области.

3. Архитектура RAG-Graph в контексте обеспечения информационной безопасности

Архитектура системы построена на принципах разделения ответственности между модулями извлечения знаний (Ingestion Pipeline) и модулем восстановления и генерации контекста (Retrieval & Generation). Такое двухуровневое проектирование позволяет одновременно обеспечивать высокое качество структурного анализа входящих данных и стабильную генерацию ответов, учитывающих как локальные семантические признаки, так и глобальные причинно-следственные зависимости внутри предметной области информационной безопасности.

В качестве инфраструктурной основы используется микросервисный подход, где каждый сервис отвечает за строго определённый этап обработки данных [22]. Данные распределены между тремя специализированными хранилищами: Neo4j (граф знаний), Qdrant (векторная БД), PostgreSQL (источники и текстовые чанк-фрагменты) [12, 23], что обеспечивает масштабируемость, отказоустойчивость и возможность независимой оптимизации каждого компонента.

3.1. Общая структура архитектуры

RAG-Graph состоит из двух ключевых подсистем:

1. Ingestion Service — обеспечивает анализ входящих документов, извлечение сущностей и связей, дедубликацию и построение графовой структуры знаний.

2. Retrieval & Generation Service — реализует гибридный поиск релевантной информации, объединяя результаты поиска по векторным представлениям и выводы из графа знаний, после чего формирует итоговый контекст для LLM-модели.

Подсистемы развёрнуты как независимые микросервисы,

взаимодействующие через внутренние API, что позволяет масштабировать ingestion-процесс отдельно от пользовательских запросов и обеспечивает стабильную работу при большой нагрузке.

3.2. Ingestion Pipeline

Ingestion-пайплайн (рис. 1) реализован в виде многослойной последовательности стадий, каждая из которых направлена на постепенное преобразование необработанного текста в структурированное представление знаний.

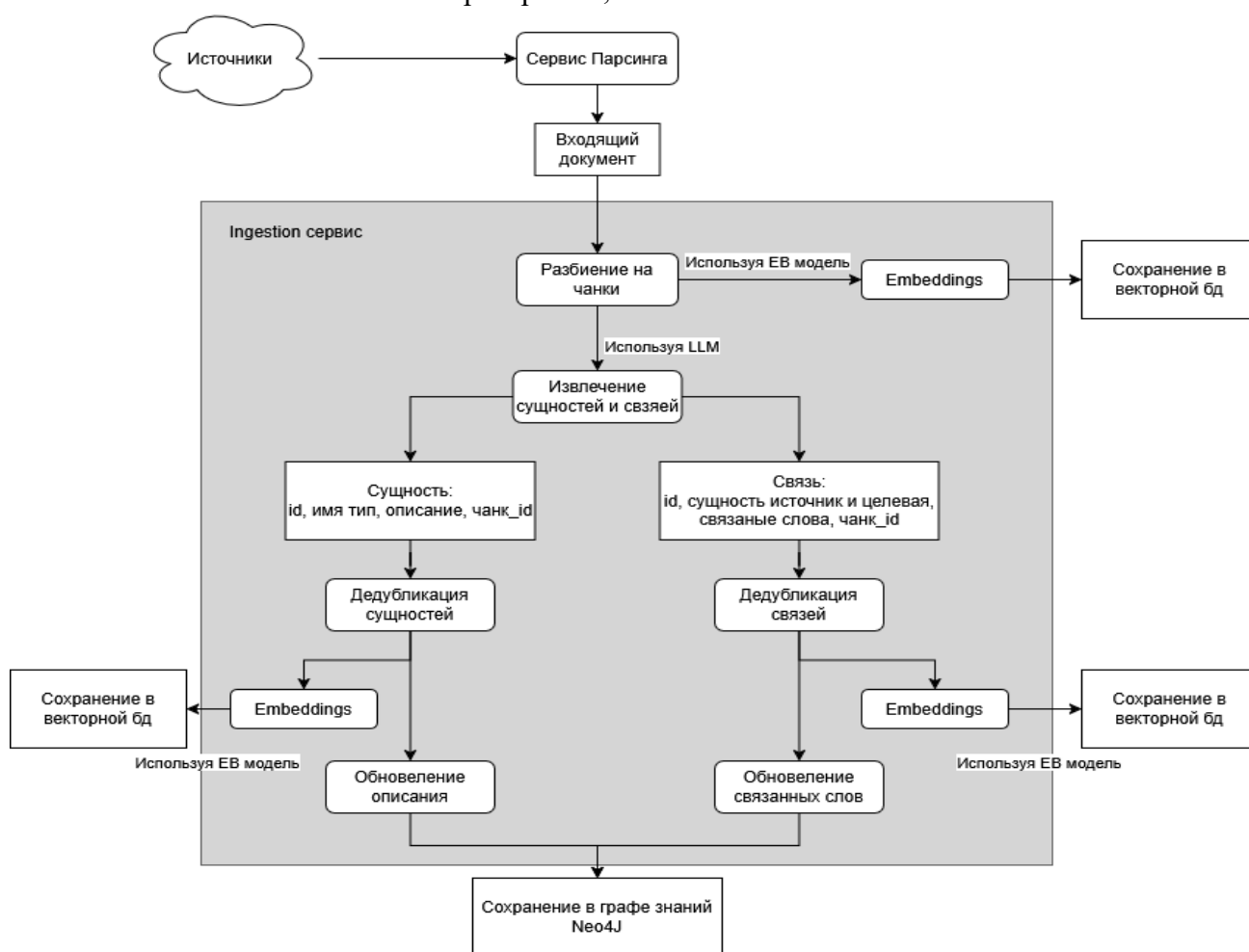


Рис. 1. Алгоритм работы Ingestion сервиса

Перед обработкой текст проходит этап нормализации: очистку от HTML-артефактов, выравнивание форматирования, устранение повторов и шумов. Затем применяется гибридный алгоритм chunking, который сочетает:

- семантическое разбиение (учёт смысловых границ и топики текста),

- ограничения по длине (для корректной работы моделей и оптимизации эмбединга).

Такой подход сохраняет содержательную целостность фрагментов и улучшает точность последующего извлечения сущностей и связей.

Для анализа чанков используется единая LLM-модель (gpt-oss:120b), что позволило

отказаться от набора специализированных NER/RE-моделей, недостаточно качественных для предметной области ИБ и мультязычной среды. Модель извлекает:

- тип сущности,
- нормализованное имя,
- текстовое описание,
- связанные сущности и характер связи,
- вспомогательные признаки и метаданные.

Такой подход обеспечивает высокую полноту и способность корректно обрабатывать слабоструктурированные фрагменты новостных и аналитических данных.

Одной из ключевых задач является выявление повторяющихся сущностей, возникающих при обработке разных документов. Используется комбинированный алгоритм:

- нормализация имени сущности,
- вычисление MD5-хэша (для устойчивых типов, кроме CIA-метрик),
- построение эмбединга (nomic-embedding),
- поиск ближайших кандидатов в Qdrant,
- проверка косинусного сходства (порог ≥ 0.9).

При совпадении сущность считается дубликатом и объединяется с существующей записью; иначе создаётся новая. Аналогично обрабатываются и связи. Такой механизм позволяет постепенно формировать консистентный граф знаний даже при обработке больших объёмов потока новостей и сообщений.

Пайплайн завершает batch-вставка в Neo4j и сохранение эмбедингов в Qdrant. PostgreSQL используется как базовое хранилище исходных чанков и метаданных о документах.

Таким образом, Ingestion-процесс формирует тройную модель данных: текст — векторы — граф, где каждая форма используется своей частью архитектуры.

3.3. Retrieval & Generation Pipeline

Retrieval & Generation модуль генерирует конечный набор данных для последующего предоставления отчёта и соединяет два источника контекста (рис. 2):

- глобальный, основанный на поиске по эмбедингам (Qdrant),
- локальный, основанный на анализе графа знаний (Neo4j).

Такое объединение позволяет компенсировать недостатки классического RAG, который работает только с текстовыми фрагментами и не учитывает логическую структуру предметной области.

Запрос пользователя проходит два параллельных пути:

1. извлечение "поверхностных" терминов (конкретные техники, уязвимости, группы);
2. извлечение "абстрактных" понятий (категории угроз, последствия).

Разделение увеличивает полноту поиска и позволяет охватывать как низкоуровневые факты, так и высокоуровневые концепты.

Для каждого набора ключевых слов строится embedding; затем выполняется поиск по Qdrant с динамическим определением K (зависит от плотности эмбедингов в окрестности запроса). Из найденных результатов формируется глобальный контекст: фрагменты текста, конкретные факты и определения.

По ключевым сущностям и найденным embedding-кандидатам осуществляется расширение графа на глубину 1–2 (ego-network).

Результатом является локальный контекст, включающий:

- связанные кампании,
- последовательности атак,
- связи «группировка → техника → уязвимость → последствия»,
- структурные зависимости, не видимые в исходных документах.

Помимо прочего, было принято решение использовать LLM модель для задач дополнительной генерации запросов к графу знаний. Данный этап позволяет уточнять недостающие аспекты контекста, подстраиваясь под конкретный запрос конечного пользователя.

Такой формат обеспечивает стабильность генерации и снижает вероятность галлюцинаций модели за счёт отделения структурных знаний от текстовых.

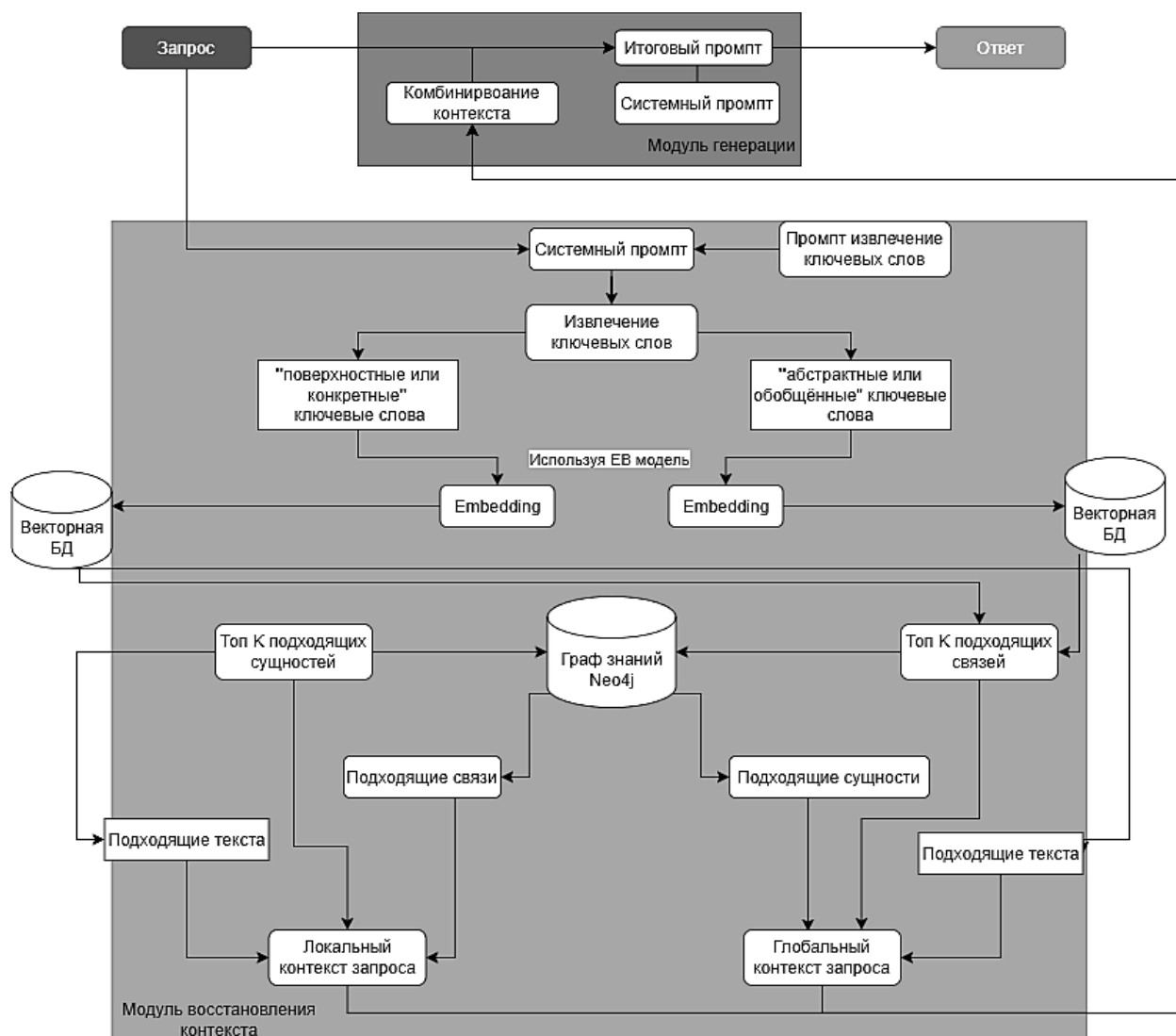


Рис. 2. Алгоритм работы Retrieval & Generation сервиса

3.4. Микросервисная инфраструктура и взаимодействие компонентов

Архитектура системы развёрнута как набор независимых сервисов:

1) Parsing Service — сбор входящих данных (например, Telegram-каналы, текстовые отчёты и пр.);

2) Ingestion Service — нормализация, извлечение знаний, сохранение в БД;

3) Retrieval & Generation Service — обслуживает пользовательские запросы;

Хранилища:

4) PostgreSQL — документы и метаданные,

5) Qdrant — векторные представления сущностей, связей и чанков,

6) Neo4j — граф знаний, объединяющий все источники.

Межсервисное взаимодействие построено так, чтобы каждый сервис мог

масштабироваться независимо. Ingestion работает пакетно и параллельно, что позволяет обрабатывать потоки данных в реальном времени. Retrieval стабилен при высокой нагрузке благодаря стратегии кэширования и разграничению уровней поиска.

3.5. Поток данных: от источника к ответу

Последовательность обработки данных Ingestion сервисом представлена следующими последовательными шагами.

1. Документ поступает в Parsing Service.

2. Ingestion Service нормализует текст, разбивает на чанки, извлекает сущности и связи, выполняет дедупликацию.

3. Эмбединги сохраняются в Qdrant, структура — в Neo4j, текст — в PostgreSQL.

4. При поступлении пользовательского запроса Retrieval & Generation Service извлекает ключевые слова, выполняет локальный (векторный) и глобальный (графовый) поиск.

5. Оба вида контекста комбинируются в структурированном виде и подаются LLM.

6. Модель генерирует обоснованный ответ, учитывающий факты, связи и зависимости.

3.6. Значимость архитектуры для анализа угроз

Представленная архитектура сочетает гибкость RAG-подхода и формальную строгость графового моделирования, что обеспечивает высокую точность в задачах:

- выявления скрытых зависимостей между событиями,
- сопоставления группировок, техник и последствий,
- обобщения слабоструктурированных новостных данных,
- построения объяснимых отчётов по рискам.

Использование единой LLM как для ingestion, так и для retrieval гарантирует согласованность терминологии и стабильность извлекаемых структур, а графовая дедупликация создаёт устойчивую базу знаний, развивающуюся по мере поступления новых данных.

4. Примеры прикладных задач, решаемых с помощью RAG-Graph

Архитектура RAG-Graph позволяет решать широкий спектр аналитических задач в области информационной безопасности, включая анализ угроз, формирование причинно-следственных цепочек атак, выявление активных киберпреступных группировок, а также подготовку данных для последующего расчёта рисков эксплуатации уязвимостей. Ниже представлены два ключевых сценария практического применения графа знаний и векторных представлений.

Помимо прочего стоит рассмотреть так же и оборудование, используемое в реализации системы. В качестве графического ускорителя (GPU) используется наиболее оптимальная модель

для этих задач – NVIDIA H100 с 80 гигабайтами видеопамати. Использование подобных ресурсов значительно ускоряет работу системы, а также существенно повышает точность предоставляемых ответов.

4.1. Обнаружение исходных данных для расчёта риска эксплуатации уязвимостей

Одним из важнейших результатов работы системы является автоматизированное извлечение и классификация данных, необходимых для проведения риск-анализа. Большая часть материалов в источниках информации по ИБ представляет собой слабоструктурированные отчёты и аналитики: новости, технические обзоры, сообщения об инцидентах, описания уязвимостей и кампаний АРТ-группировок [24, 25].

В качестве источников в текущей версии системы использованы следующие каналы:

- Positive Technologies (PT Research, PT Expert Analytics), Kaspersky, RST Report Hub и другие – технические детальные разборы уязвимостей и методов эксплуатации;
- БДУ ФСТЭК России – нормативно-аналитические публикации об уязвимостях и инцидентах;
- SecurityLab.ru, SecAtor и др. СМИ по ИБ – оперативные новости, содержащие упоминания CVE, описания атак, ИБ-инцидентов и группировок;
- Telegram-каналы по ИБ – оперативные данные, содержащие сведения об эксплоитах, вредоносных кампаниях, утечках, ботнет-активности.

Эти источники обладают важным свойством — высокой плотностью фактов, которые невозможно использовать в аналитике без структурирования. RAG-Graph устраняет эту проблему путём извлечения сущностей, семантического сопоставления и построения причинно-следственных связей.

После выполнения Ingestion-процесса все данные поступают в граф знаний Neo4j, где объединяются в единую модель предметной области: группировки – техники – уязвимости – последствия – инфраструктура – события и т.д. (рис. 3).

Это позволяет:

- выявлять связи между уязвимостью и техниками её эксплуатации (например, CAPEC-66 → CWE-89 → CVE-2024-XXXX → Data Breach),
- обнаруживать группировки, использовавшие конкретную уязвимость или технику (например, APT41 использует SQL injection/Privilege Escalation),
- агрегировать события, связанные с конкретным CVE, даже если информация разбросана по множеству статей,
- определять последствия эксплуатации (CIA Impact), упомянутые в реальных инцидентах.

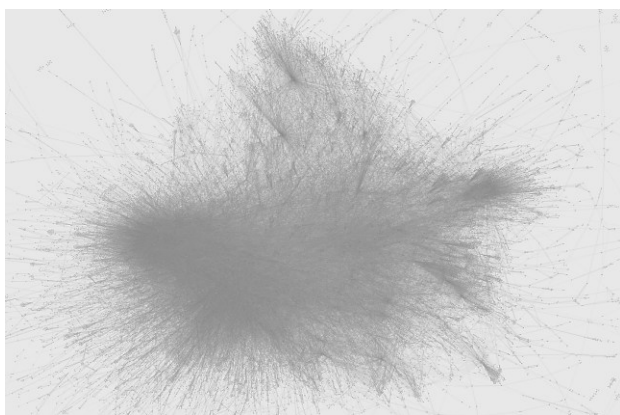


Рис. 3. Визуализация графа знаний из Neo4j

4.1.1. Анализ векторных коллекций: семантическое группирование угроз

В системе используются две коллекции Qdrant:

- Коллекция текстовых чанков (содержит нормализованный фрагмент текста и embedding)
- Коллекция сущностей (embedding каждой сущности, полученной после дедупликации и сопутствующая метайнформация)

Эмбединги создаются моделью `openai-embed-text`, оптимизированной для информационного поиска и кластеризации.

Qdrant предоставляет возможность визуализировать многомерные embeddings через UMAP/TSNE-проекции, что позволяет увидеть структуру данных до построения графа (рис. 4).

Эта визуализация крайне полезна для:

- выделения тематических кластеров (уязвимости, группировки, malware,

инциденты), обнаружения плотных областей (часто упоминаемые CVE),

- анализа качества дедупликации сущностей,
- оценки тематической близости источников



Рис. 4. Проекция embeddings в выборке из 6000 сущностей

4.1.2. Метрики обработки данных и производительности системы

Для оценки практической применимости и вычислительной эффективности разработанной системы были собраны количественные метрики, характеризующие основные этапы обработки данных в Ingestion-пайплайне и графовом анализе. Измерения проводились в ходе обработки реальных источников информации по тематике информационной безопасности и отражают суммарные затраты времени на ключевые операции извлечения, нормализации и структурирования знаний. Основной целью анализа метрик являлась проверка масштабируемости системы и выявление потенциальных узких мест при увеличении объема входных данных. В табл.3 приведены основные показатели производительности, зафиксированные в процессе работы системы.

Полученные значения подтверждают, что основная вычислительная нагрузка приходится на этапы генерации embedding и извлечения сущностей и связей с использованием LLM, что соответствует современным архитектурам нейросетевого анализа текстов. При этом использование пакетной обработки и параллельного исполнения позволяет эффективно масштабировать ingestion-процесс при росте количества источников.

Таблица 3

Метрики производительности Ingestion-процесса и графового анализа

Метрика	Описание	Значение
Среднее время обработки одного чанка	Полный цикл обработки текстового фрагмента, включая нормализацию, извлечение сущностей и сохранение	15 с
Время построения embedding чанка	Генерация векторного представления текстового фрагмента (nomic-embed-text)	0.3 с
Время NER/RE через LLM	Извлечение сущностей и семантических связей с использованием LLM	14 с
Время дедупликации сущностей и связей	Поиск ближайших эмбедингов в Qdrant и вычисление косинусного сходства	0.4 с
Время пакетной вставки в Neo4j	Batch-вставка узлов и рёбер графа знаний	0.1 с
Время выполнения алгоритма Лейдена	Кластеризация графа знаний для выявления сообществ	15–30 мин
Общее количество обработанных чанков	Число текстовых фрагментов, прошедших полный Ingestion-пайплайн	8704
Общее количество извлечённых сущностей	Число уникальных узлов графа знаний после дедупликации	33,537
Общее количество извлечённых связей	Число рёбер графа знаний	88,792
Количество выявленных сообществ	Число кластеров, полученных алгоритмом Лейдена	1,457

Отдельного внимания заслуживает время выполнения алгоритма Лейдена, которое остаётся в допустимых пределах даже при увеличении размеров графа, что подтверждает целесообразность его применения для анализа структур киберугроз и выявления сообществ в реальных условиях эксплуатации системы. Процесс запуска алгоритма происходит принудительно, модератором системы, поэтому затраченное время не оказывает влияния на основной Ingestion алгоритм.

4.1.3 Подготовка данных для последующего риск-анализа

Одной из ключевых целей системы является обеспечение входных данных для расчёта эмпирических рисков эксплуатации уязвимостей. Для этого собирается статистика: упоминаний эксплуатаций, последствий, затронутых нарушений свойств информации (CIA), используемых техник,

- задействованных группировок, успешности атак.

Особое внимание уделяется сущности CIA_IMPACT, которая не проходит процедуру дедупликации. Это сделано по концептуальным причинам:

- каждое упоминание нарушения КЦД в источниках соответствует отдельному инциденту,

- дедупликация привела бы к потере информации о частоте,

- статистика используется при расчёте эмпирического нормализованного вектора риска К-Ц-Д.

Таким образом, по сущностям CIA_IMPACT система аккумулирует количество упоминаний нарушений конфиденциальности (К), целостности (С) и доступности (D) при реализации уязвимости. Эти данные передаются далее в модуль, реализующий методологию риск-анализа.

Исходя из этого, RAG-Graph выступает данным-ориентированным слоем, обеспечивающим объективную статистическую базу для последующего расчёта:

- логарифмически преобразованных значений,
- нормализованного вектора (K', C', D'),
- сравнительной оценки уязвимостей.

Фактически система формирует фундамент для перехода от декларативной модели CVSS к эмпирически подтверждённой модели реального риска.

4.2. Генерация аналитических отчётов и рекомендаций по управлению рисками информационной безопасности

Одной из прикладных задач, решаемых системой RAG-Graph, является автоматизированное формирование аналитических отчётов, ориентированных на поддержку принятия решений в области управления рисками информационной безопасности. В отличие от традиционных систем, ограниченных статическими оценками уязвимостей (например, CVSS), разработанный подход опирается на совокупность эмпирических данных, извлечённых из открытых источников, и их структурированное представление в графе знаний.

Система формирует отчёты, объединяющие результаты графового анализа, статистику нарушений свойств информации (КЦД), сведения о применяемых техниках атак и активности киберпреступных группировок. Это позволяет перейти от описания отдельных уязвимостей к анализу их реального контекста эксплуатации (рис. 5,6).

4.2.1. Структура аналитического отчёта

Генерируемый отчёт имеет иерархическую структуру и включает следующие ключевые разделы:

- обзор угрозы, содержащий агрегированную информацию о целевой группировке или классе уязвимостей;
- критические уязвимости, выявленные на основе статистики упоминаний, связей с техниками атак и группировками;
- анализ вектора КЦД, отражающий распределение последствий по конфиденциальности, целостности и доступности;
- рекомендации по управлению рисками, сформированные на основе графа знаний и выявленных причинно-следственных связей;
- визуализация ландшафта рисков, включающая графики и диаграммы (распределение ущерба, вероятность, динамика);

- сводную таблицу уязвимостей с количественными и качественными характеристиками;

- детализированный разбор отдельных CVE, включая описание, вероятность эксплуатации и последствия;

- использованные источники и релевантные фрагменты, обеспечивающие прозрачность и проверяемость выводов.

Завершая описание структуры аналитического отчёта, целесообразно рассмотреть его содержательное наполнение на конкретном примере использования системы. В качестве иллюстрации возможностей разработанного подхода далее анализируется отчёт, сформированный системой RAG-Graph в ответ на пользовательский запрос: ««Проведи анализ киберпреступной группировки Akira и предоставь подробный аналитический отчёт»».

Данный запрос ориентирован на получение комплексной оценки угроз, связанных с деятельностью конкретной киберпреступной группировки, и включает анализ используемых уязвимостей, вероятности их эксплуатации, характера последствий, а также рекомендаций по снижению соответствующих рисков. Выбор группировки Akira обусловлен её активной деятельностью, наличием задокументированных инцидентов эксплуатации уязвимостей и достаточным объёмом доступных эмпирических данных в открытых источниках.

В последующих подразделах приводится детальный разбор результатов, полученных в рамках данного запроса, с акцентом на интерпретацию аналитических показателей, формируемых системой, и их практическую значимость для задач управления рисками информационной безопасности.

4.2.2. Обзор угрозы и выявленные критические уязвимости

В рамках выполнения запроса на анализ киберпреступной группировки Akira система RAG-Graph сформировала сводный обзор угрозы, основанный на данных графа знаний, включающего сведения об уязвимостях, техниках атак и зафиксированных последствиях эксплуатации. Анализ

проводился на основе шести уязвимостей (CVE), связанных с деятельностью данной группировки, выявленных в открытых источниках и внутреннем репозитории системы.

Сводные показатели анализа показывают, что в рассматриваемом наборе отсутствуют уязвимости с критическим уровнем риска, а средний интегральный риск-скор по всем CVE составляет 0.091, что соответствует низкому уровню. При этом среднее значение показателя EPSS, отражающего вероятность эксплуатации уязвимостей в реальной среде, составляет 0.306, тогда как средний показатель потенциального ущерба равен 0.560 и относится к среднему уровню. Данное соотношение указывает на характерную для группировки Akira модель угроз, при которой используются преимущественно уязвимости с умеренным эксплуатационным потенциалом, но способные приводить к значимым последствиям при целенаправленном применении.

Наибольший практический интерес представляет уязвимость CVE-2023-27532, отнесённая системой к среднему уровню риска. Для данной уязвимости зафиксирован максимальный риск-скор (0.3154) и высокий показатель EPSS (0.8104), что свидетельствует о её активной эксплуатации в реальной среде. Анализ вектора К–Ц–Д показывает, что последствия эксплуатации данной уязвимости в наибольшей степени затрагивают конфиденциальность ($K = 0.81$) и целостность данных ($C = 0.73$), при этом влияние на доступность выражено слабее ($D = 0.33$). Связь данной CVE с техникой удалённого выполнения кода указывает на её потенциальное использование на ранних этапах атаки, включая первоначальный доступ и закрепление в системе.

Остальные уязвимости, выявленные в ходе анализа, формально относятся к низкому уровню риска, однако демонстрируют различный характер угроз. Так, уязвимость CVE-2024-31839 характеризуется высоким значением EPSS (0.8019) при умеренном потенциальном ущербе, что указывает на вероятность её использования в атаках, ориентированных преимущественно на нарушение конфиденциальности без

существенного воздействия на целостность и доступность. Аналогичный профиль наблюдается у CVE-2024-40766, для которой отмечено умеренное влияние на конфиденциальность при минимальном воздействии на остальные свойства информации.

Особое место в анализе занимает уязвимость CVE-2025-55234, для которой был зафиксирован крайне высокий показатель потенциального ущерба (0.9634) при низком интегральном риск-скор. Анализ связей в графе знаний показывает, что данная уязвимость ассоциирована с возможностью реализации атак отказа в обслуживании, обхода контроля доступа и Zero-Click-сценариев. Вектор К–Ц–Д для данной CVE демонстрирует выраженные нарушения по всем трём измерениям, что делает её потенциально опасной в условиях целенаправленной эксплуатации, несмотря на низкую вероятность её массового использования.

Таким образом, проведённый обзор угрозы показывает, что деятельность группировки Akira характеризуется использованием ограниченного набора уязвимостей с различными профилями риска. Основной вклад в совокупный риск вносит одна уязвимость среднего уровня, обладающая высокой вероятностью эксплуатации, тогда как остальные CVE формируют фон потенциальных и латентных угроз. Это подчёркивает необходимость комплексного анализа, учитывающего не только формальные оценки критичности, но и эмпирические данные об эксплуатации и последствиях атак, что и реализуется в рамках подхода RAG-Graph.

4.2.3. Формирование рекомендаций на основе графа знаний

Работа механизма может быть проиллюстрирована на примере аналитического отчёта, сформированного системой в ответ на запрос по киберпреступной группировке Akura. В рамках анализа было выявлено шесть уязвимостей, ассоциированных с деятельностью данной группировки, при этом их распределение по уровням риска оказалось неравномерным: одна уязвимость

была отнесена к среднему уровню риска, остальные — к низкому.

Ключевым элементом приоритизации рекомендаций стала уязвимость CVE-2023-27532, для которой был зафиксирован наибольший риск-скор (0.3154), а также высокий показатель EPSS (0.8104), свидетельствующий о высокой вероятности эксплуатации в реальной среде. Дополнительным фактором послужил анализ вектора К–Ц–Д, показавший значительное влияние на конфиденциальность ($K = 0.81$) и целостность ($C = 0.73$). В графе знаний данная уязвимость связана с техникой удалённого выполнения кода, что типично для начальных этапов компрометации. В результате система автоматически приоритизировала рекомендации, направленные на немедленный патчинг данной уязвимости и устранение её эксплуатационных цепочек.

В то же время анализ уязвимости CVE-2025-55234 продемонстрировал иной характер риска. Несмотря на низкий интегральный риск-скор, потенциальный ущерб от её эксплуатации оказался крайне высоким (0.9634), а вектор К–Ц–Д показал выраженные нарушения по всем трём измерениям. Связи в графе знаний указывают на возможность реализации атак отказа в обслуживании, обхода контроля доступа и Zero-Click-сценариев. Это привело к формированию рекомендаций, ориентированных не на срочный патчинг, а на усиление мониторинга сетевого трафика, внедрение средств обнаружения атак и сегментацию инфраструктуры.

Для уязвимостей с низким уровнем риска, таких как CVE-2024-31839 и CVE-2024-40766, рекомендации носят превентивный характер. Несмотря на сравнительно низкие значения риск-сбора, для одной из них был зафиксирован высокий показатель EPSS (0.8019), что указывает на потенциальную эксплуатацию в будущем. В данном случае система предлагает регулярный аудит, автоматизированное сканирование и включение данных уязвимостей в план планового управления патчами, а не экстренные меры реагирования.

Рекомендации в отчёте формируются не по шаблонному принципу, а на основе анализа графа знаний, который связывает

уязвимости с техниками атак, средствами защиты и последствиями эксплуатации. В процессе генерации учитываются:

- частота упоминаний эксплуатации уязвимости;
- связи с конкретными группировками или кампаниями;
- типичные сценарии атак (по MITRE ATT&CK / CAPEC);
- зафиксированные нарушения КЦД;
- наличие и тип контрмер, связанных с аналогичными техниками.

Таким образом, рекомендации представляют собой **контекстно-зависимые компенсирующие меры**, приоритизированные с учётом вероятности и потенциального ущерба, а не формальный перечень общих советов.

4.2.3. Роль статистики КЦД в отчётах

Особенностью системы является использование статистики упоминаний нарушений свойств информации (КЦД) в качестве входных данных для анализа. Каждое зафиксированное упоминание нарушения конфиденциальности, целостности или доступности рассматривается как отдельный инцидент, что позволяет аккумулировать эмпирическую информацию о реальных последствиях атак.

Полученные значения используются:

- для построения вектора риска (К–С–D),
- для визуализации ландшафта рисков,
- для приоритизации уязвимостей,
- для обоснования рекомендаций по снижению риска.

Важно отметить, что на данном этапе в рамках статьи рассматривается именно подготовка и агрегация данных, тогда как формальные методы расчёта итоговых риск-метрик выносятся за рамки текущей работы и являются предметом дальнейших исследований.

4.2.4. Визуализация ландшафта рисков и аналитических показателей

Визуализация в системе RAG-Graph используется как средство аналитической интерпретации результатов, полученных в ходе анализа графа знаний. Основная цель визуализации заключается в наглядном

представлении взаимосвязей между вероятностью эксплуатации уязвимостей, потенциальным ущербом и характером последствий, а также в поддержке принятия решений при приоритизации мер защиты.

Одним из ключевых элементов визуализации является представление ландшафта рисков (рис. 5), в котором каждая уязвимость описывается набором количественных характеристик, включая интегральную оценку риска, вероятность

эксплуатации (EPSS) и показатели потенциального ущерба. В рамках анализа группировки Akira уязвимости распределяются неравномерно: одна из них занимает область повышенного риска за счёт сочетания высокой вероятности эксплуатации и значимого ущерба, тогда как остальные сосредоточены в зоне низкого риска, характеризуясь либо низкой вероятностью эксплуатации, либо ограниченным практическим воздействием.

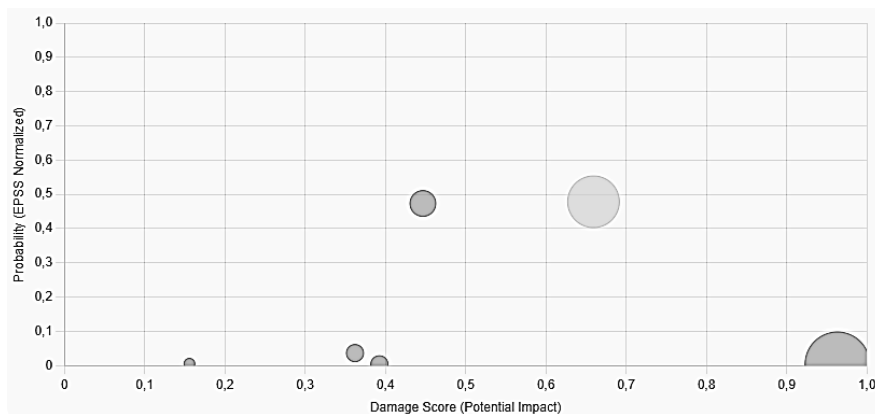


Рис. 5. Представление ландшафта рисков

Дополнительно используется визуальное представление вектора К–Ц–Д, отражающего распределение последствий эксплуатации уязвимостей по свойствам конфиденциальности, целостности и доступности. Для анализируемого примера характерно доминирование компоненты конфиденциальности, что подтверждается как средними значениями вектора, так и суммарной статистикой «сырых» нарушений. Такое представление позволяет выявлять преобладающий тип ущерба и соотносить его с типовыми сценариями атак, характерными для рассматриваемой группировки.

Отдельное значение имеет визуализация распределения уязвимостей по уровням риска и их сравнительное представление. Даже при отсутствии уязвимостей критического уровня подобная визуализация позволяет выявлять аномальные случаи, например уязвимости с низкой формальной оценкой риска, но высоким потенциальным ущербом. В анализе группировки Akira к таким случаям относится уязвимость CVE-2025-55234, которая визуально выделяется на фоне остальных за счёт экстремального значения показателя ущерба.

Таким образом, визуализация в системе RAG-Graph выполняет функцию аналитического слоя, позволяющего обобщать и интерпретировать результаты количественного анализа. Она способствует выявлению приоритетных уязвимостей, формированию целостного представления о ландшафте рисков и повышает прозрачность выводов, делая их более понятными для специалистов по управлению рисками и принятию решений.

4.2.5. Оценка качества классификации и извлечения информации

Для оценки качества работы системы в части автоматизированной классификации сущностей и последствий атак предусмотрен отдельный этап валидации результатов. В качестве базовых метрик используются стандартные показатели качества классификации. Точность (precision), полнота (recall) и F-мера являются метриками, которые используются при оценке большей части алгоритмов извлечения информации [26]. Оценка проводится на вручную размеченной выборке фрагментов, содержащих упоминания уязвимостей. Такой

подход позволяет количественно оценить надёжность извлечения сущностей и корректность их отнесения к соответствующим категориям. Точность системы в пределах класса – это доля документов, действительно принадлежащих данному классу относительно всех документов, которые система отнесла к этому классу. Полнота системы – это доля найденных классификатором документов, принадлежащих классу относительно всех документов этого класса в тестовой выборке.

$$Precision = \frac{TP}{FP + TP} = \frac{3}{2 + 3} = 0.6,$$

$$Recall = \frac{TP}{FN + TP} = \frac{3}{4 + 3} = 0.67,$$

где TP — истинно-положительное решение;
 TN — истинно-отрицательное решение;
 FP — ложно-положительное решение;
 FN — ложно-отрицательное решение.

Понятно, что чем выше точность и полнота, тем лучше. Но в реальной жизни максимальная точность и полнота не

Рассмотрим статистику по группировке C10p за 2025 год. Система извлекла из графа знаний следующий перечень связанных уязвимостей: CVE-2025-61884, CVE-2025-61882, CVE-2025-55234, CVE-2025-30745, CVE-2025-14262. Согласно агрегаторам информации по действиям киберпреступным группировок, истинно связанными уязвимостями являются: CVE-2025-61882, CVE-2025-61884, CVE-2025-30745 и CVE-2025-30746;

достижимы одновременно и приходится искать некий баланс. Поэтому, хотелось бы иметь некую метрику, которая объединяла бы в себе информацию о точности и полноте нашего алгоритма. Именно такой метрикой является F-мера.

$$F = 2 \frac{Precision * Recall}{Precision + Recall} = 2 \frac{0.6 * 0.67}{0.6 + 0.67} = 0.633070866.$$

Таким образом, значение F-меры, равное 0.63, свидетельствует о сбалансированном соотношении между точностью и полнотой выявления связей. Полученный результат можно считать приемлемым для ранних этапов накопления и анализа данных, а также типичным для систем, функционирующих в условиях неполноты, разнородности и зашумлённости источников информации. Следует отметить, что по мере расширения корпуса данных и уточнения онтологии ожидается рост как точности, так и полноты классификации, что в дальнейшем позволит повысить общее качество анализа.

Заключение

В статье рассмотрен подход к применению архитектуры RAG-Graph для автоматизированного анализа киберугроз и подготовки данных для последующего риск-анализа в области информационной безопасности. Описаны ключевые технологические компоненты решения,

включая использование больших языковых моделей, векторных представлений текста и графов знаний для интеграции разнородных открытых источников информации.

Предложена модель знаний о киберугрозах, основанная на ограниченном, но семантически значимом наборе сущностей и связей, позволяющем формировать интерпретируемый граф знаний без избыточного усложнения онтологии. Показано, что использование LLM для извлечения сущностей и отношений обеспечивает мультиязычность и предметную адаптивность при анализе специализированных источников в сфере информационной безопасности.

Разработан и описан процесс сбора и агрегирования данных (ingestion), включающий нормализацию текста, гибридное разбиение на чанки, параллельное извлечение сущностей и связей, дедупликацию на основе векторного сходства и формирование графа знаний. Применение

алгоритма Лейдена позволило выявлять устойчивые сообщества взаимосвязанных сущностей, отражающие характерные кластеры киберугроз.

На прикладном примере продемонстрирована возможность использования полученных данных для выявления исходной информации, необходимой для расчёта рисков эксплуатации уязвимостей. Полученные значения метрик качества подтверждают работоспособность предложенного подхода на ранних этапах накопления данных и соответствуют показателям систем, функционирующих в условиях неполноты и зашумлённости источников.

Перспективы дальнейших исследований связаны с расширением корпуса анализируемых данных, уточнением онтологии предметной области, интеграцией формализованных методов количественной оценки рисков, что позволит использовать RAG-Graph архитектуру в качестве основы для интеллектуальных систем поддержки принятия решений в области информационной безопасности.

Список литературы

1. Check Point Research. Cyber Attack Trends Report 2024 // URL: <https://www.checkpoint.com/cyber-hub/threat-prevention/cyber-security-report/> (дата обращения: 10.12.2025).
2. ENISA. Threat Landscape 2024 // URL: <https://www.enisa.europa.eu/publications/threat-landscape-2024> (дата обращения: 10.12.2025).
3. MITRE ATT&CK Team. APT Groups and Techniques // URL: <https://attack.mitre.org/> (дата обращения: 10.12.2025).
4. Behl A., Behl K. Cyberwar: The Next Threat to National Security and What to Do About It. Oxford University Press, 2017.
5. Hogan A. et al. Knowledge Graphs // ACM Computing Surveys, 2021.
6. Ehrlinger L., Wöß W. Towards a Definition of Knowledge Graphs // SEMANTICS, 2016.
7. Lewis P. et al. Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks // NeurIPS, 2020.
8. Mialon G. et al. Augmented Language Models: a Survey // arXiv:2302.07842, 2023.
9. OpenAI. GPT Models and Applications // URL: <https://platform.openai.com/docs> (дата обращения: 10.12.2025).
10. Devlin J. et al. BERT: Pre-training of Deep Bidirectional Transformers // NAACL, 2019.
11. Reimers N., Gurevych I. Sentence-BERT // EMNLP, 2019.
12. Robinson I., Webber J., Eifrem E. Graph Databases. O'Reilly, 2015.
13. Izacard G. et al. Few-shot Learning with Retrieval Augmented Language Models // arXiv, 2022.
14. Microsoft Research. GraphRAG: Structuring Retrieval for LLMs // URL: <https://www.microsoft.com/en-us/research/blog/graphrag/> (дата обращения: 10.12.2025).
15. Wang J. et al. Knowledge-Augmented Generation // ACL, 2020.
16. Gruber T. A Translation Approach to Portable Ontology Specifications // Knowledge Acquisition, 1993.
17. MITRE. ATT&CK Framework // URL: <https://attack.mitre.org/> (дата обращения: 10.12.2025).
18. NIST. National Vulnerability Database (CVE, CWE) // URL: <https://nvd.nist.gov/> (дата обращения: 10.12.2025).
19. Wei J. et al. Chain-of-Thought Prompting Elicits Reasoning // NeurIPS, 2022.
20. Huang Z. et al. Multilingual Named Entity Recognition: A Survey // ACL, 2021.
21. Traag V., Waltman L., van Eck N. From Louvain to Leiden // Scientific Reports, 2019.
22. Newman S. Building Microservices. O'Reilly, 2015.
23. Qdrant Documentation // URL: <https://qdrant.tech/documentation/> (дата обращения: 10.12.2025).
24. Positive Technologies. Threat Intelligence Reports // URL: <https://www.ptsecurity.com/ru-ru/research/> (дата обращения: 10.12.2025).
25. ФСТЭК России. Банк данных уязвимостей // URL: <https://bdu.fstec.ru/> (дата обращения: 10.12.2025).

26. Powers D. Evaluation: From Precision, Recall and F-Measure // Journal of Machine Learning Technologies, 2011.

Воронежский государственный технический университет
Vronezh State Technical University

Финансовый университет при Правительстве Российской Федерации
Financial University under the Government of the Russian Federation

Государственный научно-исследовательский испытательный институт проблем технической
защиты информации ФСТЭК России
State Research and Testing Institute for Technical Information Security Problems FSTEC of Russia

Поступила в редакцию [дата]

Сведения об авторах

Остапенко Владимир Юрьевич – студент, Воронежский государственный технический университет e-mail: vladimirostapenkost@gmail.com

Карпеев Дмитрий Олегович – канд. техн. наук, директор Центра разработки программного обеспечения, Финансовый университет при Правительстве Российской Федерации, email: dokarpeev@fa.ru

Сердечный Алексей Леонидович – канд. техн. наук, начальник лаборатории, Государственный научно-исследовательский испытательный институт проблем технической защиты информации ФСТЭК России, доцент, Воронежский государственный технический университет, e-mail: alex-voronezh@mail.ru

Васильченко Алексей Павлович – аспирант, Финансовый университет при Правительстве Российской Федерации, e-mail: rainichek@yandex.ru

INTELLIGENT CYBER THREAT ANALYSIS SYSTEM BASED ON THE RAG-GRAPH NEURAL NETWORK PLATFORM: SOFTWARE AND HARDWARE

V.Yu. Ostapenko, D.O. Karpeev, A.L. Serdechniy, A.P. Vasilchenko

Modern cyberthreat analysis systems face a fundamental challenge: quickly synthesize information from multiple, heterogeneous data sources while preserving context and accuracy. Large language models (LLMs), despite their capabilities, often suffer from hallucinations and insufficient depth of understanding of complex relationships between cybercrime entities. Traditional full-text search approaches are ineffective at uncovering hidden patterns of interaction between groups, attack techniques, and vulnerabilities. This paper presents the RAG-Graph architecture, which combines three components into a single system: graph knowledge bases for structuring relationships between entities, vector databases for semantic search, and local LLMs for intelligent reporting. The key innovation lies in combining graph traversal with vector similarity, which enables solving critical cybersecurity problems.

Keywords: RAG-Graph, vectorization, artificial intelligence, cybercrime, knowledge graph.

Submitted [дата]

Information about the authors

Vladimir Yuryevich Ostapenko – student, Voronezh State Technical University, e-mail: vladimirostapenkost@gmail.com

Dmitry Olegovich Karpeev – Cand. Sc. (Technical), Director of the Software Development Center, Financial University under the Government of the Russian Federation, e-mail: dokarpeev@fa.ru

Alexey Leonidovich Serdechniy – Cand. Sc. (Technical), Head of Laboratory, State Research and Testing Institute for Technical Information Security Problems FSTEC of Russia, Associated Professor, Voronezh State Technical University, e-mail: alex-voronezh@mail.ru

Alexey P. Vasilchenko – graduate student, Financial University under the Government of the Russian Federation, e-mail: rainichek@yandex.ru